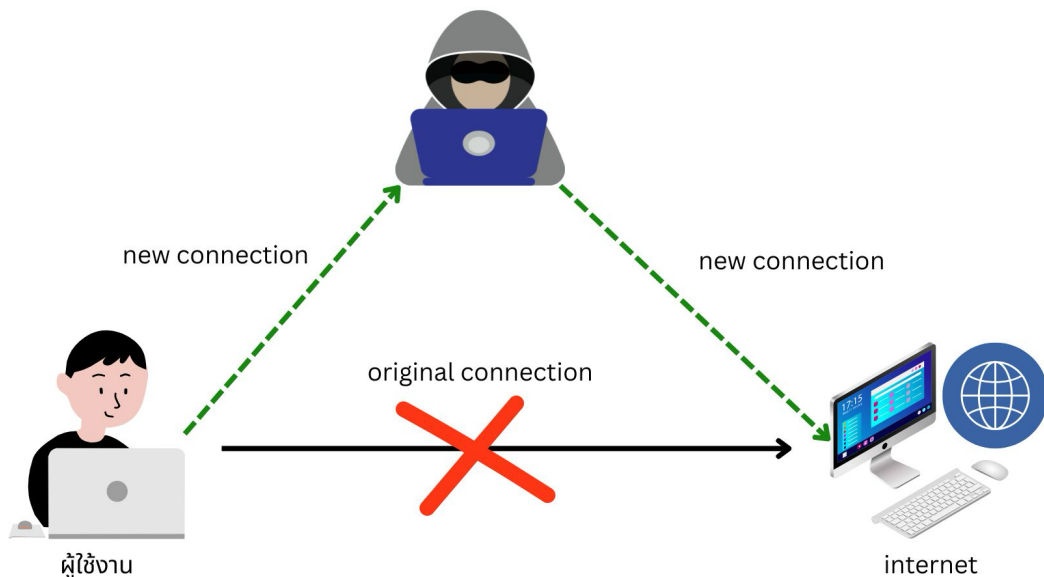


Man-in-the-Middle (MitM) Attacks

Man-in-the-Middle (MITM) คือ การโจมตีทางออนไลน์ประเภทหนึ่งโดยจะใช้วิธีดักฟังการสื่อสารระหว่างคน 2 คนหรือปลอมตัวเป็นบุคคลใดบุคคลหนึ่งเพื่อขโมยข้อมูลของเหยื่อโดยที่พวกเขาไม่รู้และไม่ยินยอมสามารถขโมยข้อมูลส่วนตัวต่าง ๆ ได้อย่างเช่น หมายเลขบัตรเครดิต การเข้าสู่ระบบในช่องทางโซเชียลมีเดียอย่างพวก Username และ Password เป็นต้น โดยจะทำการติดตั้งไวรัสและมัลแวร์ลงในอุปกรณ์ของเหยื่อมักใช้ในการขโมยข้อมูลทางการเงิน เช่น การชักชวนผู้ที่ไม่ให้ไปยังเว็บไซต์ธนาคาร โดยประเภทของการโจมตีมี ดังนี้



1. Network-based MITM

การโจมตีประเภทนี้จะทำการสกัดกั้นการรับส่งข้อมูลระหว่างอุปกรณ์หรือเครือข่ายทั้งสองเครื่อง ซึ่งสามารถทำได้โดยการติดตาม Traffic ที่ส่งผ่านเครือข่ายคอมพิวเตอร์หรือการเปลี่ยนเส้นทาง Traffic ไปยังเว็บไซต์ปลอมหรือเซิร์ฟเวอร์ที่แฮกเกอร์ควบคุมอยู่

2. SSL Stripping

SSL Stripping จะกำหนดเป้าหมายในการจู่โจมโดยแฮกเกอร์จะชักชวน Client ในการขอรับบริการจาก Server และบังคับให้ Server ตอบกลับด้วยข้อมูลที่ไม่ได้แปลงเป็นรหัสลับจากนั้นจะทำการดักเก็บข้อมูลและแก้ไขก่อนจะส่งกลับไปยัง Client

3. DNS spoofing

DNS spoofing คือ การขัดขวางและเปลี่ยนข้อมูลของ DNS ให้ไปยังเว็บไซต์หรือเซิร์ฟเวอร์ปลอมโดยที่เหยื่อไม่รู้ตัว ซึ่งข้อมูลของเหยื่อจะถูกขโมยหรือเพื่อเผยแพร่ข้อมูลเป็นต้น

4. Email hijacking

การโจมตีประเภทนี้จะทำการสวมรอยอีเมลโดยระบุเป็นชื่อผู้ส่งที่ต้องการสวมรอยเพื่อหลอกเหยื่อให้เกิดการเข้าใจผิดโดยอาจจะส่งไฟล์แนบไวรัสหรือให้กรอกข้อมูลส่วนตัวและขโมยข้อมูลมาใช้ในการที่ผิด

5. Rogue Wi-Fi access points

เป็นตัวกระจายสัญญาณ Wi-Fi ปลอมที่ทำให้ผู้ที่ต้องการเชื่อมต่อตัวกระจายสัญญาณ Wi-Fi จริงไปเชื่อมต่อกับของปลอมแทน ซึ่งเมื่อเชื่อมต่อแล้วแฮกเกอร์สามารถขโมยข้อมูลต่าง ๆ เช่น อีเมล รหัสผ่าน และบัญชีธนาคารไปได้

วิธีรับมือกับ Man-in-the-Middle (MitM) Attacks

1. การเชื่อมต่อที่ปลอดภัย

เวลาที่เราเข้าเว็บไซต์ตัวเว็บไซต์จำเป็นที่จะต้องมี “HTTPS” นำหน้าในแถบ URL เช่น <https://www.ert.co.th/> แทนที่จะเป็น “HTTP” ที่มีความปลอดภัยน้อยกว่าเนื่องจากตัว HTTP จะส่งข้อมูลเป็นข้อความธรรมดาหากโดนแฮกเกอร์ดักจับข้อมูลจะทำให้ง่ายต่อการขโมยข้อมูลเป็นอย่างมาก ซึ่งแตกต่างกับ HTTPS ที่จะใช้ SSL/TLS ในการแปลงข้อมูลเป็นรหัสลับก่อนอย่างตัวเลขหรือตัวอักษร

2. หลีกเลี่ยงอีเมลฟิชชิง

สร้างอีเมล Phishing เพื่อหลอกให้เหยื่อเปิดอีเมลเหล่านั้น อีเมล Phishing จะมีลักษณะเหมือนบัญชีทางการ เช่น บัญชีธนาคาร โดยอีเมลพวกนี้จะขอให้เหยื่อคลิกลิงก์เพื่อป้อนข้อมูลส่วนตัวต่าง ๆ หรือพาผู้ใช้ไปยังเว็บไซต์ปลอมเพื่อให้เหยื่อดาวน์โหลดซอฟต์แวร์ที่เป็นอันตรายบนอุปกรณ์ ดังนั้นผู้ใช้ควรคิดให้รอบคอบก่อนเปิดอีเมลที่มาจากแหล่งที่ไม่ได้รับการยืนยันหรือไม่รู้จัก

3. การใช้เครือข่ายส่วนตัวเสมือนหรือ VPN

ใช้ VPN เมื่อทำธุรกรรม การเข้าสู่ระบบออนไลน์ในแต่ละแพลตฟอร์มและการเชื่อมต่อกับ Wi-Fi หรือ hotspots สาธารณะเพื่อป้องกันข้อมูลส่วนตัวไม่รั่วไหล โดย VPN จะช่วยปกปิดตัวตนของเราได้รวมถึงช่วยปกปิดข้อมูลส่วนตัวของเราอีกด้วย